Table of Contents

Cisco Secure Workload — TSA Rail Cybersecurity

Reference Design | Freight & Passenger Railroad Owner/Operators

Version: 1.0 (draft — pending SME review) | **Standard:** TSA Security Directive 1580/82-2022-01E, *Rail Cybersecurity Mitigation Actions and Testing* (effective May 3, 2026 – May 2, 2027; this series is renewed annually — confirm the active revision letter) and the sister SD 1582-21-01 series for public transportation and passenger railroads | **Audience:** Freight railroad Owner/Operators subject to 49 CFR 1580.101, TSA-designated freight and passenger railroads, and the cybersecurity teams supporting them | **Environment:** IT estate supporting rail OT (PTC back office, dispatch/CAD, signaling-support servers, historians, engineering workstations, vendor-access hosts — *not* the signaling, wayside, or locomotive devices themselves)

Reader's Guide

Who this is for. Freight railroad Owner/Operators subject to 49 CFR 1580.101, TSA-designated freight and passenger railroads, rail transit agencies working to the sister SD 1582-21-01 series, and the cybersecurity, IT, and OT teams supporting them. Also useful for railroads not yet TSA-designated who want to align proactively.

The single most important thing to understand. TSA inspects against your TSA-approved Cybersecurity Implementation Plan — not against the Security Directive text, and not against a vendor document. The SD requires you to establish a plan describing the specific measures and schedule for achieving the outcomes in Sections III.A–III.E. Every CSW artifact in this reference design must be mapped to a measure in that plan. An evidence pack keyed only to SD provision numbers will not land in an inspection.

Why this framework fits CSW unusually well. Section IV.C.2.e lists, among the records TSA inspectors may demand, **"East-West Traffic" of Operational Technology systems** and **"North-South Traffic" between Information and Operational Technology systems** — and Section VII defines both terms. Section III.B then makes network segmentation the first substantive requirement, with prescriptive sub-requirements for interdependency lists, external-connection lists, and logical zone boundaries. You are not translating CSW output into the regulator's vocabulary; the regulator is already using it.

Scope boundary you must understand before reading further. Cisco Secure Workload (CSW) is a workload-protection and segmentation platform for **IT estate** — servers, virtual machines, containers, and cloud workloads. CSW does **not** enforce policy on wayside interface units, signal and interlocking controllers, locomotive onboard PTC hardware, grade-crossing predictors, track circuits, or any other Level 0–2 device, and does not perform deep packet

inspection of rail or OT protocols. CSW's contribution is at the **IT side of the IT/OT boundary** and within the IT systems that support rail operations. See section 2.

Questions this reference design helps you answer:

- *Section III.A — do I have a current, defensible Critical Cyber System inventory, including the PTC systems the SD makes mandatory, and the business services whose loss causes operational disruption?*
- *Section III.B.1 — can I produce the IT/OT interdependency list, the external-connection list, and the zone-boundary description the SD requires, generated from observed behaviour rather than drawn by hand?*
- *Section III.B.2 — can I prove unauthorized inter-zone communication is actually prevented, not merely prohibited on paper?*
- *Section III.D.2.b — can I document and audit communications between OT and external systems that deviate from my identified baseline?*
- *Section III.D.4 — if an IT-side incident threatens OT safety and reliability, can I isolate, and can I show I have tested it?*
- *Section III.E.2.b/3 — can I prioritize CISA KEV vulnerabilities on Critical Cyber Systems, and evidence compensating mitigations where patching would degrade operations?*
- *Section III.F.2.b — when the architecture design review needs "verification and validation of network traffic," where does that come from?*
- *Section IV.C.2 — when an inspector asks for east-west and north-south traffic, what exactly do I hand over?*

What you'll need. Your TSA-approved Cybersecurity Implementation Plan, your Critical Cyber System register, your current Cybersecurity Assessment Plan, your most recent Cybersecurity Architecture Design Review, your PTC system documentation, and your documented OT network ranges.

Where to start. Section 2 for the IT/OT scope boundary — read it before claiming anything. Section 3 if you are reconciling the Critical Cyber System register; sections 4–5 if Section III.B segmentation is the priority; section 6 if access-control evidence is the gap; section 7 if continuous monitoring is the open item; section 11 for the inspector response guide.

Important. TSA SDs are issued under TSA's regulatory authority; designated Owner/Operators are required to comply. If an Owner/Operator has delegated measures to a **Managed Security Service Provider** or an **Authorized Representative**, the Owner/Operator **retains sole responsibility** for compliance, and both parties are liable for the representative's non-compliance. Nothing in this reference design substitutes for the accountable officer's responsibility under the SD or for the formal TSA inspection response.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	**Live** network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement **operates**

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: Compliance evidence playbook (full step-by-step) · About CSW (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to SD provisions in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:tsa-rail`, `ccs_id`, `ccs_function`, `zone`, `ot_facing`, `ptc`
- ☐ CSW scope created matching the approved plan's zone model
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥1 week (≥30 days for OT-facing tiers)
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Multi-factor authentication, shared-account management, domain trust review, email and web filtering, packet capture, physical security of locomotive PTC components, personnel and training programmes, and the Cybersecurity Implementation Plan itself still require separate programmes. CSW addresses the **workload-resident** slice on the IT side: segmentation, flows, process context, vulnerability reachability, and change drift.

CSW effectiveness for this framework

- Section III.B.1 interdependency, external-connection, and zone-boundary lists generated from observed behaviour
- Section III.B.2.a inter-zone enforcement with a denied-connections log proving the control operates
- Section III.D.2.b baseline-deviation detection for OT-to-external communications
- Section IV.C.2.e east-west and north-south traffic records, which the SD names explicitly

Compared to manual programmes: a railroad's network diagram is accurate on the day it is drawn and progressively less so afterwards, while the Cybersecurity Assessment Plan requires at least one-third of the plan's measures to be assessed every year and 100 percent over three years. CSW ties evidence to **live workload behaviour** and regenerates it on demand, which turns the annual assessment from an archaeology project into a query.

---

1. Overview

Security Directive 1580/82-2022-01E imposes mandatory, performance-based cybersecurity requirements on freight railroad carriers identified in 49 CFR 1580.101 and on additional TSA-designated freight and passenger railroads. The requirements were first issued in October 2022 and have been renewed annually; revision **E** is effective **May 3, 2026 through May 2, 2027**. TSA has stated it intends to codify them permanently through rulemaking.

The SD's substantive requirements fall under six sections:

Provision	Topic	CSW relevance
Section III.A	Critical Cyber System identification (**PTC mandatory**)	Inventory + labelling on the IT side; designation stays with the operator
Section III.B	Network segmentation (IT/OT, both directions)	**Direct** — the strongest fit; zone enforcement plus the III.B.1 documentation set
Section III.C	Access control measures	**Narrow** — network least privilege only; identity is not CSW's layer
Section III.D	Continuous monitoring and detection	**Direct** on baseline deviation, continuous collection, and OT isolation
Section III.E	Unpatched-system risk reduction	**Direct** on CISA KEV prioritization and compensating

Provision	Topic	CSW relevance
		mitigations
Section III.F	Cybersecurity Assessment Plan	**Direct** on the architecture-review input artifacts
Section IV.C.2	Records TSA may inspect	**Direct** — including east-west and north-south traffic, named explicitly

A defined term worth noting early. A **Critical Cyber System** is "any Information or Operational Technology system or data that, if compromised or exploited, could result in **operational disruption**," and the definition explicitly **includes business services**. Crew scheduling, consist and waybill management, and movement planning can therefore be Critical Cyber Systems even though they are not signaling systems. Railroads routinely under-scope here.

Two handling rules. TSA determined this SD **is not** Sensitive Security Information, so the requirement text may be discussed openly. **Everything you submit to TSA under it *is* SSI** under 49 CFR part 1520. Once a CSW export is incorporated into a plan, assessment, or report, handle it as SSI.

---

2. The IT/OT Scope Boundary

Read this before claiming anything. Over-claiming here is the fastest way to lose an inspector's confidence on the provisions where CSW genuinely is the primary evidence source.

In CSW's reach (IT-side)	Out of CSW's reach (OT device layer)
PTC Back Office Server and supporting hosts	Locomotive onboard PTC components
Dispatch / computer-aided dispatch (CAD) servers	Wayside interface units, signal controllers
Signaling-support and interlocking-support servers	Grade-crossing warning devices
Historians, reporting and analytics databases	Track circuits, switch machines
Engineering and maintenance workstations	Traction power field devices
Train management, movement planning, crew scheduling	Programmable logic controllers
Vendor and MSSP remote-access hosts	—
Identity, PKI, logging, and patch infrastructure	—

The PTC back office is the point worth making. Section III.A.2 makes PTC systems a **mandatory** Critical Cyber System, and the back office is a server workload — squarely in CSW's reach. A railroad can produce genuine, workload-level Critical Cyber System evidence for its single most inspection-sensitive system.

The SD's segmentation requirement runs in **both** directions — IT protected from OT as well as OT from IT. CSW addresses the IT side of that requirement only. Your OT-aware monitoring stack (Cisco Cyber Vision, Claroty, Nozomi, Dragos, or equivalent) and your IT/OT boundary firewalls remain the controlling artifacts at and below the boundary.

---

3. Section III.A — Critical Cyber System Identification

The SD requires identification of every Critical Cyber System, and makes PTC systems mandatory for operators required to install PTC under 49 CFR part 236 subpart I, or voluntarily operating it under subpart H or I. If an operator determines it has **no** Critical Cyber Systems, it must notify TSA in writing within 60 days.

CSW does not perform Critical Cyber System designation. That is an operational risk decision your accountable officer signs. CSW hosts the labels that every downstream IT-side control depends on.

CSW Implementation:

```
Step 1: Receive the Critical Cyber System register from the
        operations risk function
  → Per IT workload supporting a CCS:
      ccs_id        reference to your Cybersecurity Implementation
                    Plan register entry
      ccs_function  ptc-bos | dispatch-cad | signaling-support |
                    historian | engineering-wks | train-mgmt |
                    identity | patch-repo | vendor-access
      ot_facing     true | false  (does the workload reach into OT?)
      ptc           true | false  (III.A.2 mandatory CCS)
      site          subdivision / yard / facility
      managed_by    internal | authorized-rep | mssp

Step 2: Apply consistent labels to every CSW-managed workload
  CSW UI → Inventory → Bulk Label
  Mandatory: ccs_id, ccs_function, zone, ot_facing, ptc, site,
             managed_by, compliance:tsa-rail

Step 3: Build CSW Scopes to mirror the approved plan's zone model
  CSW UI → Organize → Scopes → New
  → Recommended hierarchy:
        Root
        └── Rail-Critical-Cyber-Systems
            ├── OT-Facing-IT
            │   ├── PTC-Back-Office        (mandatory CCS — III.A.2)
```

```
│   ├── Dispatch-and-CAD
│   ├── Signaling-Support
│   ├── Historians
│   └── Engineering-Workstations
├── CCS-Supporting-IT
│   ├── Train-Mgmt-and-Planning
│   ├── Identity-and-PKI
│   ├── Logging-and-Monitoring
│   └── Patch-Repositories
├── Privileged-Access-Paths
├── Corporate-IT                (default-deny source)
└── External
    ├── Internet-Edge
    └── Vendor-and-MSSP-Access
```

```
Step 4: Run the under-scoping check
  → The CCS definition includes BUSINESS SERVICES whose loss causes
    operational disruption. Assess crew scheduling, movement
    planning, consist and waybill management — this is where
    under-scoping hides.
  → Cross-check CSW count vs. the register; reconcile the delta with
    the accountable officer before sign-off
```

Evidence: Per-scope membership snapshot (CSV) with workload identity, OS, owner, `ccs_id`, `ccs_function`, `ot_facing`, `ptc`, `site`, and last-seen timestamp. This is the IT-side companion to your Section III.A register.

---

4. Section III.B.1 — Segmentation Documentation

Section III.B.1 is unusually prescriptive. It requires a list and description of four things, and CSW generates three of them from observed behaviour rather than from a drawing.

CSW Implementation:

```
III.B.1.a — IT/OT system interdependencies
  CSW UI → Investigate → ADM
  → Run ADM ≥ 14 days on OT-Facing-IT and CCS-Supporting-IT
  → The dependency graph IS the interdependency list: the SD defines
    interdependencies as "relationships of reliance ... that must be
    maintained for those systems to operate"
  → Export the cluster-to-cluster edge list with ports and processes

III.B.1.b — All external connections
  CSW UI → Investigate → Flow Search
  Filter: source or destination outside documented operator ranges
  → Enumerates every observed external connection, including the ones
    absent from the documented architecture
  → Tag vendor and MSSP paths via managed_by for Section II.A.2
```

```
III.B.1.c — Zone boundaries
  → The CSW scope tree IS the logical zone model. The SD asks for
    zones "based on criticality, consequence, and operational
    necessity" — carry those as labels:
        zone, operational_disruption_impact, ccs_function
  → Export the scope tree + label schema and cross-reference it to
    the zone model in the approved plan

III.B.1.d — Transit only when necessary for validated purposes
  → Implemented as policy, not documentation: see section 5. Each
    allow rule carries a business or operational justification in the
    workspace notes; everything unjustified is denied and logged.
```

Critical reconciliation step. If the CSW scope tree and the approved plan's zone model diverge, the CSW export stops being evidence and becomes a contradiction an inspector will pursue. Reconcile before you export.

Evidence: (a) interdependency edge list dated within the period; (b) external-connection inventory; (c) scope tree + label schema export; (d) observed-vs-documented delta report.

---

5. Section III.B.2 — Zone Enforcement

Section III.B.2.a requires controls that **prevent** unauthorized communication between zones. Section III.B.2.b prohibits OT services traversing IT and vice versa unless the content is encrypted or otherwise secured. The first is CSW's strongest claim in this framework; the second is a boundary (see section 10).

CSW Implementation:

```
Step 1: Create the zone-enforcement workspace
  CSW UI → Defend → Segmentation → New Workspace
  Name:  tsa-rail-zone-enforcement-{site}
  Scope: Rail-Critical-Cyber-Systems (site = {site})

Step 2: Import the ADM baseline from section 4
  → Reject noise clusters; rename clusters to operational roles
  → Capture a maintenance window in the observation period

Step 3: Layer the SD-aligned rule set on the baseline

  Absolute policies:
  DENY  Corporate-IT                  → OT-Facing-IT
(III.B.2.a)
  DENY  OT-Facing-IT                  → Internet-Edge
(III.B.1.d)
  DENY  Vendor-and-MSSP-Access        → PTC-Back-Office
(III.C / II.A.2)
  DENY  External                      → Rail-Critical-Cyber-Systems
```

```
(III.B.1.b)
  DENY  OT-Facing-IT                  → OT-Facing-IT
(no implicit east-west)

  Allowlist policies (each with a documented justification):
  ALLOW Dispatch-and-CAD              → PTC-Back-Office
tcp/<ptc-port-tls>
  ALLOW PTC-Back-Office               → Historians
tcp/<db-port-tls>
  ALLOW Rail-Critical-Cyber-Systems   → Identity-and-PKI
tcp/636, tcp/88
  ALLOW Privileged-Access-Paths       → OT-Facing-IT
tcp/22, tcp/3389
  ALLOW Rail-Critical-Cyber-Systems   → Logging-and-Monitoring
tcp/443, udp/514
  ALLOW Patch-Repositories            → Rail-Critical-Cyber-Systems
tcp/443

  Catch-all:
  LOG   Any                           → OT-Facing-IT
(unmatched inbound — III.D.3.a)
  LOG   OT-Facing-IT                  → Any
(unmatched outbound — III.D.2.b)
  LOG   Any                           → Any
(plaintext crossing zones — III.B.2.b)

Step 4: Run in Simulation for ≥ 30 days
  → Longer than this series' usual 2 weeks: rail traffic is seasonal
    and schedule-driven, and a short window misses patterns
  → Resolve every legitimate-but-blocked flow with the asset owner;
    document each exception in the workspace notes

Step 5: Promote to Enforce, absolute denies first
  → Gate by change management
  → Assess Section VI amendment impact: a permanent change (45+ days)
    to an approved segmentation measure must be filed with TSA within
    50 days of taking effect
```

Why the last absolute deny matters. Section IV.C.2.e.iii makes **east-west traffic within a trust zone** an inspectable record, which means "it is all inside one zone" is not an answer. Denying implicit intra-zone traffic and allowlisting the justified paths is what produces a defensible east-west record.

Every port is specified in its TLS-bearing form deliberately. Section III.B.2.b conditions cross-boundary traversal on the content being encrypted. If the only rule that makes a system work is the cleartext port, you have documented a III.B.2.b gap rather than closed one — which is useful, but record it as such.

Evidence: (a) workspace export per site; (b) simulation → enforcement transition log; (c) Denied Connections log as proof the control operates; (d) quarterly enforcement diff report.

6. Section III.C — Access Control Measures

Set expectations here. The SD's access-control section is predominantly about **identity**, which is not CSW's layer. CSW delivers *network* least privilege; most of III.C is evidenced elsewhere.

Provision	Requirement	Where the evidence comes from
III.C.1	Memorized-secret authenticator reset policy, aligned to NIST SP 800-63	Identity provider and OS policy
III.C.2	**MFA**, or compensating controls for OT components	Cisco ISE, Duo, or equivalent
III.C.3	**Least privilege and separation of duties**	**CSW (network layer)** + IdP for user/admin privilege
III.C.4	Shared-account limitation and management	Account management / privileged-access tooling
III.C.5	Domain trust relationship review	Directory services
III.C.6	PTC locomotive **physical security** alternative	Physical security programme

CSW Implementation — network least privilege (III.C.3 only):

```
Step 1: Deny-by-default at the workload identity layer
  → Every flow must match an explicit allow; everything else is
    denied with audit logging
  → Identity for CSW policy = workload + scope + label set, not IP or
    subnet (IPs reassign in virtualised and cloud estates)

Step 2: Separate functions that have no operational reason to talk
  → Default: workloads in different ccs_function categories may not
    communicate
  → Explicit allow only for documented operational paths

Step 3: Bound the privileged-access path
  → ALLOW: {documented MFA-VPN pool} → Privileged-Access-Paths
  → ALLOW: Privileged-Access-Paths → OT-Facing-IT  tcp/22, tcp/3389
  → DENY:  any other source → OT-Facing-IT administrative ports

Step 4: Cadence-based review
```

```
  → Quarterly: sunset any allow rule whose last-observed flow is
    older than 90 days
  → Annual: full ruleset review with the accountable officer
```

Worth flagging on III.C.6. It is a genuine relief valve. Operators subject to 49 CFR 232.105(h)(1–4), 236.3, or 236.553 may rely on the physical measures already used for those rules for PTC components **installed on locomotives**, instead of implementing III.C.1–5 there. It applies only to those components, and the plan must state which physical measures are relied upon.

Evidence: (a) policy export with rule provenance and last-flow timestamp; (b) quarterly access review minutes; (c) sunset log.

---

7. Section III.D — Continuous Monitoring and Detection

CSW is the primary evidence source for three of the four subsections and a supporting input to the rest.

CSW Implementation:

```
III.D.2.b — Baseline-deviation auditing  [PRIMARY]
  → The SD requires you to "document and audit any communications
    between the Operational Technology system and an external system
    that deviates from the Owner/Operator's identified baseline of
    communications." This is ADM baseline + deviation detection; the
    SD's own wording describes the artifact.
  CSW UI → Investigate → ADM → compare to the approved baseline
  → Alert on new source/destination pairs crossing the boundary
  → Export the deviation report monthly

III.D.3.a — Continuous collection and analysis  [PRIMARY]
  → Continuous flow, process, and policy-violation telemetry on
    Critical Cyber Systems and systems directly connected to them
  CSW UI → Defend → Forensics → Rules
  → Out-of-the-box: privilege escalation, persistence, lateral
movement
  → Custom rules worth adding for rail:
        "Process on PTC back office writes to startup paths"
        "New listening port opened on a dispatch server"
        "Outbound to non-allowlisted destination from a historian"

III.D.4 — OT isolation on IT compromise  [PRIMARY]
  → Build this as a STANDING, UNAPPLIED workspace, before you need it:
    Workspace: tsa-rail-emergency-isolation  (staged, not enforced)
      DENY  Corporate-IT              → OT-Facing-IT
      DENY  CCS-Supporting-IT         → OT-Facing-IT
      DENY  Vendor-and-MSSP-Access    → Rail-Critical-Cyber-Systems
      ALLOW Privileged-Access-Paths   → OT-Facing-IT
tcp/22, tcp/3389
  → TEST IT during a planned maintenance window and RECORD the test
```

```
  → The evidence an inspector wants is not that you could isolate —
    it is that you have, and that you know how long it took

III.D.1.b / III.D.1.d / III.D.1.e / III.D.2.a / III.D.2.c
[SUPPORTING]
  → Policy can deny known-malicious addresses and C2/Tor destinations;
    the reputation feeds are external
  → Process and hash telemetry identifies unauthorized code execution;
    blocking it is EDR and application control
  → Egress flow records per workload support domain auditing;
    domain-level attribution needs DNS logging

III.D.2.d — SOAR  [SUPPORTING]
  CSW UI → Manage → Data Tap → SIEM
  → Splunk, QRadar, Sentinel, Cisco XDR
  → Tag every alert with ccs_id, ptc, and site so the SOC can route
    by criticality; pair with OT sensor alerts for full coverage

III.D.3.b — Retention  [SUPPORTING]
  → CSW retention is configurable; long-term immutable retention for
    "effective investigation" belongs to the SIEM or archive
```

Not CSW: III.D.1.a malicious email (email security gateway) and III.D.1.c malicious web domains and applications (DNS/web security — Cisco Umbrella or equivalent).

Evidence: (a) baseline-deviation report; (b) detection rule catalogue with last-modified dates; (c) SIEM forwarding configuration; (d) **dated isolation test record**; (e) MTTD trend by `ccs_function`.

---

8. Section III.E — Unpatched System Risk

The SD requires a patch management strategy with a risk methodology, explicit prioritization of the **CISA Known Exploited Vulnerabilities Catalog**, and — where patching would severely degrade operational capability — a description and timeline of additional mitigations.

CSW Implementation:

```
Step 1: Continuous CVE inventory at workload level
  CSW UI → Investigate → Vulnerability Report
  → Per-workload CVE list with CVSS and exploit availability
  → Filter: ccs_id is set → the Critical Cyber System population

Step 2: KEV prioritization  [III.E.2.b — PRIMARY]
  → Filter the CVE inventory to the CISA KEV catalogue and intersect
    with ccs_function and ptc labels
  → Prioritization becomes a query rather than a spreadsheet merge
  → Export weekly; this is the III.E.2.b evidence item
```

```
Step 3: Compensating controls for unpatchable systems  [III.E.3 —
PRIMARY]
  → Railroads genuinely cannot patch on an IT cadence. Where patching
    would severely degrade operations:
        Restrict the source set for the vulnerable port to the one
          justified source
        Add behavioural detection for known exploit patterns
        LOG every flow involving the affected port
  → Record each compensating control in the workspace notes with a
    timeline — this is the III.E.3 audit trail
  → A vulnerable service made unreachable from everywhere except one
    justified source is a materially different risk from the same
    service left open, and CSW produces the evidence for that
    distinction

Step 4: Patch verification and reporting
  → After patching, CSW package inventory updates on the next
    snapshot cycle; the CVE drops from the inventory automatically
  → Monthly: CVE backlog by ccs_function and severity
  → Quarterly: mean-time-to-patch trend
  → Annual: input to the Cybersecurity Assessment Plan report
```

Evidence: (a) KEV exposure report intersected with CCS labels; (b) patch remediation tracking with ticket IDs; (c) **compensating control register with timelines** for unpatched-but-mitigated workloads.

---

9. Section III.F — Cybersecurity Assessment Plan

Section III.F requires a Cybersecurity Assessment Plan that assesses the effectiveness of the approved Cybersecurity Implementation Plan, includes an architecture design review within the first 12 months and at least every two years thereafter, and assesses **at least one-third of the plan's measures each year with 100 percent over any three-year period** — with an annual report to TSA.

CSW Implementation:

```
III.F.2.b — Architecture design review inputs  [PRIMARY]
  The SD defines the review as containing "verification and validation
  of network traffic, a system log review, and analysis to identify
  cybersecurity vulnerabilities related to network design,
  configuration, and inter-connectivity to internal and external
  systems." CSW produces all three input artifacts:

    Network traffic verification   → ADM map + flow search exports
    System log review              → flow and process logs with
                                     process attribution
    Inter-connectivity analysis    → dependency graph + external-
                                     connection inventory
```

```
  The review CONCLUSION remains a human assessment. CSW supplies the
  inputs so the reviewer analyses gaps and changes rather than
  rebuilding the as-is picture from scratch.

III.F.2.d — Sampling schedule  [SUPPORTING]
  → Because every CSW artifact is re-exportable on demand, the
    one-third-per-year schedule becomes a reporting cadence rather
    than a fresh evidence-collection exercise each cycle
  → Organise the evidence binder by plan measure, so the annual
    sample maps directly onto exports

Annual evidence pack, by SD provision:
  III.B  → workspace export; simulation→enforcement log;
           interdependency and external-connection lists;
           observed-vs-documented delta
  III.C  → policy export with rule provenance; review minutes
  III.D  → baseline-deviation report; detection catalogue; SIEM
           config; dated isolation test record
  III.E  → KEV exposure report; patch tracking; compensating-control
           register
  Cross-cutting → inventory snapshot dated to assessment start;
           configuration baseline diff; quarterly diff reports
```

Evidence: (a) annual evidence binder organised **by approved-plan measure**; (b) prior-period delta showing what changed; (c) accountable officer sign-off summary.

---

10. Reporting & Evidence — and the Boundary

Evidence package

Evidence Item	CSW Source	SD Provision	Frequency
CCS scope + label export	Organize → Scopes	III.A, IV.C.2.a	Per inspection
Interdependency map	Investigate → ADM	III.B.1.a	Quarterly
External-connection inventory	Flow Search	III.B.1.b	Quarterly
Zone model export	Scopes + label schema	III.B.1.c	Per plan update
Policy workspace export	Defend → Policy Workspaces	III.B.1.d, III.B.2.a	Per inspection
Denied Connections log	Defend → Enforcement	III.B.2.a	Continuous

Evidence Item	CSW Source	SD Provision	Frequency
Plaintext-crossing-zones report	Flow Search	III.B.2.b	Quarterly
Simulation report	Defend → Policy Workspaces	III.B, Section VI	Per change
Baseline-deviation report	Investigate → ADM diff	III.D.2.b	Monthly
Flow + process telemetry	Flow / Process Search	III.D.3.a, IV.C.2.e.i	Continuous
East-west traffic record	Flow Search, intra-zone	**IV.C.2.e.iii**	On request
North-south traffic record	Flow Search, cross-zone	**IV.C.2.e.iv**	On request
Isolation test record	Emergency isolation workspace	III.D.4	Annually + per test
KEV exposure report	Investigate → Vulnerability	III.E.2.b	Weekly
Compensating-control register	Workspace notes + policy	III.E.3	Per exception
Architecture-review input pack	ADM + inventory + logs	III.F.2.b	Every 2 years
Workload inventory	Manage → Inventory	IV.C.2.a	Monthly
CSW administrative audit log	Administration → Audit Log	III.D.3.a	Per inspection

What you must supply outside CSW

Provision	Topic	Who evidences it
III.C.1	Authenticator reset policy	Identity provider, OS policy (NIST SP 800-63)
III.C.2	MFA / OT compensating controls	Cisco ISE, Duo, or equivalent
III.C.4	Shared-account management	Account management tooling
III.C.5	Domain trust review	Directory services
III.C.6	PTC locomotive physical security	Physical security programme
III.D.1.a	Malicious email defence	Email security gateway

Provision	Topic	Who evidences it
III.D.1.c	Malicious web domain control	DNS / web security
IV.C.2.b	Firewall rules	Perimeter and IT/OT boundary firewalls — CSW policy is the workload-tier complement, not a substitute
IV.C.2.e.ii	Packet capture up to 24 hours	Capture appliance or OT sensor — **CSW records flow metadata, not payloads**

Also entirely outside CSW: the Cybersecurity Implementation Plan and its TSA approval, the Cybersecurity Assessment Plan and annual report, the Cybersecurity Incident Response Plan, incident reporting to CISA, the Cybersecurity Coordinator designation, personnel and training programmes, and the **OT device layer in its entirety**.

Encryption — the most commonly misread boundary

Section III.B.2.b permits OT services to traverse IT, and vice versa, only where "the content is encrypted or, if not technologically feasible, otherwise secured and protected to ensure integrity and prevent corruption or compromise while the content is in transit."

CSW does not encrypt application data. It contributes *detection*: the plaintext-crossing-zones filter and matching LOG rule identify, with flow-level evidence, which cross-zone paths still run cleartext protocols. Useful input to the III.B.2.b narrative in your plan — not the provision itself.

Where encryption is not technologically feasible, as is common with legacy rail protocols, the SD allows the content to be "otherwise secured and protected." A tightly scoped, enforced, and logged path is a credible component of that argument, but the argument is the operator's to make in the plan, not CSW's to assert.

---

11. TSA Inspector Response Guide

Inspector asks	You provide
"Show your Critical Cyber System inventory."	Scope + label export with `ccs_id`, `ccs_function`, `ptc`, `site`, reconciled to the register (§3)
"Demonstrate your Section III.B segmentation."	Workspace export + Denied Connections log showing blocked inter-zone attempts (§5)
"Provide your IT/OT interdependency list."	ADM dependency map with generation date (§4)

Inspector asks	You provide
"List all external connections."	External-connection inventory with vendor and MSSP paths identified (§4)
"Describe your zone boundaries."	Scope tree + label schema, cross-referenced to the approved plan's zone model (§4)
"Give me east-west traffic for this OT environment."	**Intra-zone flow records for the site — IV.C.2.e.iii, native CSW output (§10)**
"Give me north-south traffic between IT and OT."	**Cross-zone flow records at the boundary — IV.C.2.e.iv (§10)**
"Show communications that deviated from your baseline."	Baseline-deviation report from ADM diff (§7)
"How would you isolate OT if IT were compromised?"	Pre-staged isolation workspace + dated test record (§7)
"How are you prioritizing KEV vulnerabilities?"	KEV exposure report intersected with CCS labels (§8)
"You cannot patch this system. What mitigates it?"	Compensating-control register + enforced policy restricting the port (§8)
"Provide input for the architecture design review."	Traffic verification, flow/process logs, interconnectivity graph (§9)
"Provide a 24-hour packet capture."	**Not a CSW answer** — capture appliance or OT sensor (§10)
"Show your MFA implementation."	**Not a CSW answer** — identity provider evidence (§6)
"Show your firewall rules."	Perimeter and IT/OT firewall rulesets; CSW policy export as the workload-tier complement (§10)

12. Related Frameworks

The TSA Rail SD shares substantial control surface with:

- **TSA Pipeline Security Directive** — the sister TSA mode; the four performance-based outcomes are harmonized, so the zone model and evidence pack transfer closely. See TSA Pipeline reference design.
- **NERC CIP** — the bulk-electric-system analogue; identical IT-side ESP-enclave patterns apply. See NERC CIP reference design.
- **IEC 62443** — zones and conduits, the engineering vocabulary behind the SD's Section III.B zone language. See IEC 62443 reference design.

- **NIST SP 800-82 Rev 3** — OT security guidance for the estate surrounding the devices CSW does not reach. See 800-82 reference design.
- **NIST SP 800-53 Rev 5** — AC-3, AC-4, SC-7, SI-4, RA-5, CM-8 are the control-catalogue analogues of Sections III.B–III.E. See 800-53 reference design.
- **NIST SP 800-207 (ZTA)** — the deny-by-default, observability-driven posture in §5 and §7 implements the ZTA tenets in the rail IT context. See 800-207 reference design.

---

13. Disclaimer

This reference design is **draft v1** describing how Cisco Secure Workload capabilities can support a TSA Rail Security Directive cybersecurity programme on the **IT side** of the IT/OT boundary. It is **not** legal or regulatory advice and does not constitute a finding of compliance.

Specifically:

- TSA Security Directives are issued and revised by the Transportation Security Administration; this series is **renewed annually** and the revision letter advances (01, 01A … 01E). Always validate against the **current effective revision**, your inspector's current guidance, and any subsequent rulemaking that supersedes the SD.
- **TSA inspects against the Owner/Operator's TSA-approved Cybersecurity Implementation Plan**, not against the SD text and not against a vendor document. Map every artifact here to a measure in that plan.
- Designation as a covered Owner/Operator is a TSA determination. Nothing here substitutes for that designation analysis.
- Delegation to a Managed Security Service Provider or Authorized Representative does **not** transfer responsibility; the Owner/Operator retains sole responsibility for compliance.
- The SD text is not Sensitive Security Information, but **everything submitted to TSA under it is SSI** under 49 CFR part 1520. Handle CSW exports accordingly once incorporated into a plan or report.
- CSW does not enforce policy on wayside units, signal controllers, locomotive onboard PTC hardware, grade-crossing equipment, or PLCs, does not inspect rail or OT protocols, does not capture packet payloads, and is not certified as an architecture-review tool.

This document should receive subject-matter-expert review for both TSA SD regulatory accuracy and current Cisco product capability before being relied upon in a formal compliance engagement.